ISO/IEC 27001:2022

GAP Analysis Report

Version 1.0 | Tech Solution Company
Governance, Risk, & Compliance Portfolio

Prepared By: Hossam El-Deen Mohamed Shebl
Cyber security GRC analyst | Cairo, Egypt

Document Contents

- Executive summary.
- Analysis scope.
- Analysis limitations.
- Evidence gathering methods.
- Maturity Model.
- GAP Analysis Findings.
- Remediation Plan
- Conclusion.
- Appendix.

Executive Summary:

This document presents a comprehensive GAP analysis report conducted against ISO/IEC 27001:2022. The assessment measures the current information security maturity state of Tech Solution Company across key clauses of the standard, using a structured maturity model ranging from **0 (Non-existent)** to **5 (Optimized).** The target maturity level is **Level 4 — Quantitatively Managed**, aligned with the organization's 2027 strategic plan. The assessment covers current state analysis, evidence gathering, maturity scoring, gap identification, and actionable recommendations to support the organization's journey toward ISO 27001 certification.

Key Findings at a Glance:

Total Clauses Assessed	Critical Gaps (Score = 4)	High Gaps (Score = 3)	Medium Gaps (Score = 2)	Low Gap (Score<=1)
15 clauses & controls	2	5	5	3

Top two critical Gaps Requiring Immediate Action:

- **Clause 8.1 – operation planning and control:** No third-party vendor management or audit process.
- **Clause 9.2 – Internal Audit:** No audit program, schedule, or audit reports exist whatsoever.

High-Level Recommendations for Management:

- Develop a vendor management Framework covering all outsourced services.
- Establish and launch a formal internal audit program and schedule immediately.
- Conduct a management review of the ISMS and formalize meeting schedules and outputs.
- Implement Arabic – language versions of key documentation to improve staff comprehension.

Analysis scope:

Department Included:

- IT Department.
- Cybersecurity Department.
- Human resources Department (HR).
- Finance Department.
- Operational Department.

Locations Included:

- Headquarters – fifth settlement (Cairo).
- Dokki Branch.
- Sheikh Zayed Branch
- El-Zamalek Branch.

Stakeholders Consulted:

- Internal Parties: Department Heads, Internal auditors and senior employees.
- External Parties: Regulators, Third – party service providers.

Exclusions:

- Organization's overseas and abroad branches are excluded from this assessment scope at this stage.

This analysis measures the organization's current state against **ISO/IEC 27001:2022** requirements, in alignment with the organization's **2027 strategic certification plan**.

Analysis limitations:

The following limitations were identified during the conduct of this assessment and should be considered when interpreting the findings:

1. **Time Constraints:** The assessment relied on a representative sample of assets and departments rather than an exhaustive audit of every single process or requirements.
2. **Information Accuracy:** Some findings are based on interviews and documentation provided by staff. The accuracy of the analysis is limited by the completeness and honesty of the information shared by stakeholders.
3. **Design VS. Operational effectiveness:** This analysis focuses primarily on the design of controls - Whether controls exist and are documented. It may not fully validate the operational effectiveness of those controls over a long period.

Evidence gathering methods:

Comprehensive evidence was gathered using five (5) distinct methods to ensure the assessment is well-rounded and fact-based.

1- Observations:

We visited all Branches within the analysis scope and directly observed the organization's operations and the staff activities and systems. This enabled a first-hand understanding of how daily operations align with ISO 27001 requirements.

2- Questionnaires:

- **Close-ended questionnaires:** were sent to external parties to obtain precise answers on key compliance points.
- **Open-ended questionnaires:** were sent where a deeper understanding of processes was required.

3- Interviews:

We conducted Interviews with key individuals at different hierarchical levels within the organization.

Individual Interviews: Conducted with high-level managers and unit heads to obtain detailed information about processes and decision-making authority.

Group Interviews: Conducted with operational staff and senior employees to understand how processes are executed at the operational level.

4- Documentation review:

Read the relevant documents such as: Internal policy, last audit Findings, Incident logs and asset Inventory document.

5- Tools used:

We used some technical tools to check the system and processes lack such as Nessus for checking the exist vulnerabilities.

Maturity model definition:

The assessment uses a six-level maturity model (Levels 0 through 5) based on the Capability Maturity Model Integration (CMMI) framework, adapted for information security:

Level	Name	Description
0	Non-existent	The organization is not aware that there is a total absence of the identifiable processes and that this is a problem to be considered.
1	Initial	The organization is aware of the problem and the need to investigate it, However, there is no standardized process to do this and there is not general approached agreed by the management.
2	Managed	Processes have been developed to a stage where different people performing the same task are using the same procedures or the same source, However, there Is no formal training or communication of standard, It relies heavily on personal knowledge
3	Defined	Procedures have been standardized, documented and communicated through formal training and sessions, However, their use is left to individual initiative and it's likely that failures can be detected
4	Quantitatively Managed (Target)	It is easy to monitor, measure compliance, and take actions when some processes may fail to comply properly
5	Optimized	when the processes reached the highest level of practice and everything can be automated and integrated with tools that improve the quality and efficiency and make the organization adapt quickly

GAP Analysis Findings:

The table below presents the full gap analysis findings across all 15 assessed ISO 27001 clauses and Annex A controls.

	A	B	C	D	E	F	G	H	I
1	**Clause**	**Requirement Summary**	**Evidence Gathered**	**Current State Description**	**Current Maturity**	**Target Maturity**	**Gap**	**Gap Description**	**Audited by**
2	**Clause 4.1** Understanding the Context of the ORGZ.	The ORGZ shall determine external and internal issues, legal requirements and the stakeholders perceptions .	The Strategy to achieve the vision is unclear.	The ORGZ has clear Mission, Vision, and Value in action. However the Strategy to achieve the visionary plan Is not clear enough as the strategy Is not agreed by the management.	1	4	3	No Standard procedure and no management approval.	Hossam Shebl ISO 27,001 LI
3	**Clause 5.3** Organizational roles and responsibilities	Top Managemnent shall assign the appropriate INFO SEC roles and responsibilities in order to ensure that the ISMS confirms to ISO 27,001.	There Is no formal wrriten segregation of duties.	The Top management team defined INFO SEC roles, but some roles are interrelated and someones has authority to make different actions.	2	4	2	No Appropriate defined Roles policy	Hossam Shebl ISO 27,001 LI
4	**clause 6.2** INFO SEC objectives and planning	The INFO SEC objectives and Planning shall be established, measurable, Communicated with stakeholders regularly and updated.	There Is no scheduled review.	The ORGZ has a plan and objective and they are documented but they are not communicated with the all stakeholders regularly, it's limited on internal stakeholders only.	3	4	1	No updates with out stakeholders.	Hossam Shebl ISO 27,001 LI
5	**Clause 7.1** Resources	The Orgz shall determine and provide the needed resources for the implementation, maintenance and continual improvement of ISMS	No formal written approval from the Top management team.	The ORGZ allocated the needed resources but they are waiting the Top management approval.	2	4	2	No formal written approval.	Hossam Shebl ISO 27,001 LI

	A	B	C	D	E	F	G	H	I
1	**Clause**	**Requirement Summary**	**Evidence Gathered**	**Current State Description**	**Current Maturity**	**Target Maturity**	**Gap**	**Gap Description**	**Audited by**
6	**Clause 7.2 Competence**	The ORGZ shall Hire competent Employee on basis of Educational, Training and experience.	Not all security Employees ISO 27,001 LI certified.	The ORGZ has competent Security Employees but not all of them ISO 27,001 LI certified.	2	4	2	Not all employees have the appropriate certifications.	Hossam Shebl ISO 27,001 LI
7	**Clause 7.3** Awareness.	The ORGZ Shall provide regularly Security awareness to all emlpoyees to be able to do their work under the ORGZ'S Defined Policy.	There Is no formal scheduled Training sessions.	The ORGZ provides Security sessions only when significant problem or change happen.	3	4	1	No Regular Security training sessions.	Hossam Shebl ISO 27,001 LI
8	**Clause 7.5.2** Creating and Upfating Document.	The ORGZ shall create and update document and take into consideration (Format language, review date, Communication media and etc.).	The Documentation Is In English languge only.	The ORGZ Is working In Egypt, however its documentation is provided in English language only.	2	4	2	No Arabic Laguage version.	Hossam Shebl ISO 27,001 LI
9	**Clause 8.1** Operation planning and control.	The ORGZ shall control planned changes and review the consquences of unintended changes, and ensure that the outsource processes are controlled and determined.	No third-party service review or audit in place	The ORGZ does not audit or assess outsourced services provided by third parties. No formal third-party management process exists.	0	4	4	No third-party assessment, audit, or vendor management process.	Hossam Shebl ISO 27,001 LI

	A	B	C	D	E	F	G	H	I
1	Clause	Requirement Summary	Evidence Gathered	Current State Description	Current Maturity	Target Maturity	Gap	Gap Description	Audited by
10	**Clause 8.3** INFO SEC Risk Treatment.	The ORGZ shall implement INFO SEC risk treamtent plan and retain docuemnted INFO of the results.	The Documentation of the INFO SEC treament results Is In English languge only.	The ORGZ Is working In Egypt, however its documentation is provided in English language only.	2	4	2	No Arabic Laguage version.	Hossam Shebl ISO 27,001 LI
11	**Clause 9.1** Monitoring, Measurement, Analysis & Evaluation	The ORGZ shall evaluate the performance and effectiveness of the ISMS. It shall determine what needs to be monitored, the methods to be used, and when results shall be analyzed and communicated.	No formal KPIs or metrics dashboard for ISMS performance. Monitoring is ad-hoc and undocumented.	The ORGZ has not defined measurable KPIs for ISMS performance. Monitoring activities occur informally without documented methods, intervals, or assigned ownership.	1	4	3	No defined ISMS performance metrics, monitoring schedule, or formal evaluation process.	Hossam Shebl ISO 27,001 LI
12	**Clause 9.2** Internal Audit	The ORGZ shall conduct internal audits at planned intervals to provide information on whether the ISMS conforms to its own requirements and ISO 27001.	No internal audit program or schedule exists. No audit reports found.	The ORGZ has not established an internal audit program. No audit schedule, audit criteria, or audit reports are documented. Audit independence has not been addressed.	0	4	4	No internal audit program, schedule, or documented audit results exist.	Hossam Shebl ISO 27,001 LI

	A	B	C	D	E	F	G	H	I
1	Clause	Requirement Summary	Evidence Gathered	Current State Description	Current Maturity	Target Maturity	Gap	Gap Description	Audited by
13	**Clause 9.3** Management Review	Top management shall review the ISMS at planned intervals to ensure its continuing suitability, adequacy, and effectiveness.	No formal management review meetings recorded. No minutes or review outputs found.	Top management has not conducted any formal ISMS management review. There are no scheduled review meetings, no documented inputs/outputs, and no corrective actions arising from reviews.	1	4	3	No management review process, meeting schedule, or documented review outputs established.	Hossam Shebl ISO 27,001 LI
14	**Clause 10.1** Nonconformity & Corrective Action	When a nonconformity occurs, the ORGZ shall react, evaluate the need for action, implement corrective actions, and review the effectiveness of actions taken.	No nonconformity log or corrective action register found. Issues are handled informally	The ORGZ has no formal process for recording nonconformities or tracking corrective actions. Issues are addressed on an ad-hoc basis with no root-cause analysis or effectiveness review.	1	4	3	No nonconformity register, corrective action process, or root-cause analysis procedure.	Hossam Shebl ISO 27,001 LI
15	**A.5.1.1** Policy for Information Security	Information security policies and objectives shall be defined, established and approved by the top management.	The INFO Sec Policy has not been distributed to the all Employees in the ORGZ.	An Information security Policy has been signed by the top management and existed, However, It has never been distributed to all employees in the ORGZ, only persons are involved in the implementation of the ISMS are aware of the policies.	3	4	1	The Policy was not Communicated properly.	Hossam Shebl ISO 27,001 LI
16	**A.5.1.2** Review the Policies for Information Security	The Policies for Information security shall be reviewed at Planned intervals or when significant changes occur.	There Is No scheduled review.	The Policies have been existed for more than 6 months and they have not been formally reviewed by the management team yet, and there is no scheduled review.	2	5	3	The policies are not reviewed periodically.	Hossam Shebl ISO 27,001 LI

Recommendation and Remediation Plan:

- **Priority 1 – Immediate Actions (Gap = 4)**

  Clause 8.1: Establish a formal Vendor/third Management framework.

  Clause 9.2: Establish an internal audit program; Define schedule, criteria and etc.

- **Priority 2 — Short-term Actions (Gap = 3)**

  Clause 4.1: Finalize and formally document the organizational strategy. Obtain management sign-off.

  A.5.1.2: Implement a formal annual policy review cycle with documented review records..

  Clause 9.1: Define and implement ISMS KPIs, assign monitoring ownership, and document evaluation intervals.

  Clause 9.3: Schedule and conduct the first formal management review. Document inputs, outputs, and actions.

  Clause 10.1: Establish a nonconformity register and corrective action procedure including root-cause analysis.

- **Priority 3 — Medium-term Actions (Gap = 2)**

  Clause 5.3: Formalize the roles and responsibilities matrix with clear segregation of duties.

  Clause 7.1: Obtain formal written top management approval for ISMS resource allocation.

  Clause 7.2: Develop a certification roadmap to achieve ISO 27001 LI across the security team.

  Clause 7.5.2: Produce Arabic-language versions of all key ISMS documents.

  Clause 8.3: Translate risk treatment documentation into Arabic for operational staff accessibility

Conclusion:

Tech Solution Company demonstrates a foundational awareness of information security requirements under ISO/IEC 27001:2022. Several controls and policies exist in draft or partial form, indicating organizational intent. However, the majority of controls are not yet formally documented, approved, communicated, or operationally effective at the required maturity level. The two most critical gaps — absence of an internal audit program, And lack of vendor management controls, represent areas of immediate organizational risk and must be addressed before any certification readiness assessment can proceed. With focused effort, the organization is well-positioned to achieve its 2027 ISO 27001 certification target.

- Recommendation Next Steps:

1. Immediately address all Priority 1 gaps (Gap = 4) within the first month.
2. Begin Priority 2 remediation in parallel, targeting completion within 3–4 months
3. Conduct a formal management review meeting to present these findings and secure resource commitment.
4. Re-assess maturity scores in 6 months to measure improvement against this baseline.
5. Engage an external ISO 27001 consultant to conduct a Stage 1 readiness audit before 2027.

- Auditor Statement and Sign-Off:

This report has been prepared based on evidence gathered during the assessment period. The findings and recommendations represent the professional judgment of the auditor based on the information made available at the time of the assessment.

Prepared by	Hossam El-Deen Mohamed Shebl
Credential	ISO/IEC 27001 LI
Role	Cybersecurity GRC Analyst
Location	Cairo, Egypt
Version	V1.0

Appendix: Glossary of Terms and references.

- **ISMS:**
  Information Security Management System — a framework of policies and procedures including all legal, physical, and technical controls involved in an organization's information risk management
- **ISO/IEC 27001:2022:**
  The international standard specifying requirements for establishing, implementing, maintaining, and continually improving an ISMS.
- **Gap Analysis:**
  A structured assessment process that compares an organization's current state against a desired standard, identifying gaps between the two.
- **Maturity Model:**
  A framework used to evaluate the sophistication and effectiveness of an organization's processes on a defined scale (in this report: Levels 0–5).
- **Annex A Controls:**
  A set of security controls referenced in ISO 27001 that organizations may select based on their risk assessment and treatment plan.
- **ORGZ:**
  Internal abbreviation used throughout this document to refer to Tech Solution Company.
- **MFA:**
  Multi-Factor Authentication — a security mechanism requiring users to verify their identity using two or more independent factors.
- **Vendor Management:**
  The process of managing risks and compliance requirements associated with external service providers and outsourced functions.